



SEGURANÇA DA **INFORMAÇÃO**



Prof. Dr. Felipe



Quanto custa perder um dado?

- 
- CPF
 - Senha
 - Projeto
 - Nota fiscal
 - Prontuário médico
 - Pix
 - Código-fonte
 - Contrato

Pergunta: Todos possuem o mesmo valor?

Resposta: Não! O valor de uma informação depende do contexto e do impacto da sua perda, alteração ou divulgação.

ONDE EXISTE INFORMAÇÃO?



Pergunta: Qual desses lugares poderia funcionar normalmente se todas as informações desaparecessem agora?

R: Nenhum!

O que aconteceria se a informação desaparecesse?

- E se um hospital perdesse todos os prontuários?
- E se um banco perdesse o saldo das contas?
- E se uma universidade perdesse todas as notas?
- E se um supermercado perdesse o estoque?

A informação é um recurso essencial para o funcionamento de qualquer organização. Quando ela é perdida, alterada ou fica indisponível, toda a operação pode ser comprometida.

A informação é um ativo estratégico

Identidade

- CPF
- RG
- Passaporte

Acesso

- Senhas
- Tokens
- Biometria

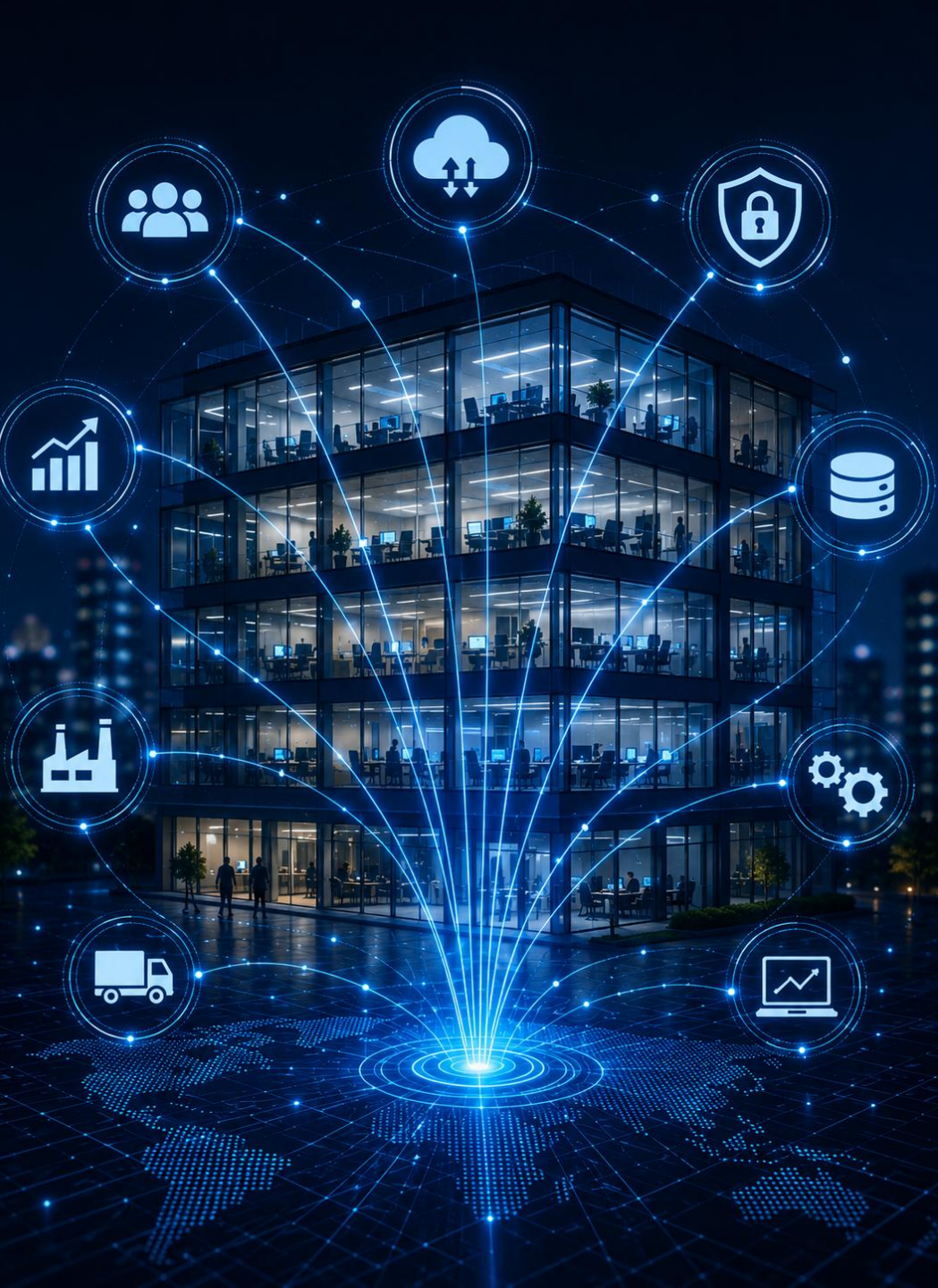
Financeiro

- Pix
- Notas fiscais
- Contratos

Negócio

- Clientes
- Banco de dados
- Estratégias

Se essas informações são tão valiosas, como podemos protegê-las?



O que é Segurança da Informação?

O objetivo não é impedir ataques.



O objetivo é proteger aquilo que é importante.



Segurança da Informação:

É o conjunto de práticas, processos e tecnologias utilizados para proteger as informações contra acessos não autorizados, alterações indevidas, perdas ou indisponibilidade.

Quem pode acessar? Quem pode alterar? Quem pode utilizar?

Pergunta: Será que proteger informação significa apenas instalar um antivírus?

Resposta: Não! O antivírus é apenas uma ferramenta.

O que significa proteger uma informação?

Proteger uma informação não significa apenas impedir que ela seja roubada.



Ela precisa permanecer **confidencial**.



Ela precisa permanecer **íntegra**.



Ela precisa estar **disponível** quando necessária.



Esses três princípios formam a base da Segurança da Informação.

Tríade CIA



Confidencialidade

A informação deve ser acessada apenas por quem possui autorização.

Garantir que informações sensíveis não sejam visualizadas por pessoas não autorizadas.

Exemplos: CPF de clientes, Dados bancários, Senhas, Prontuários médicos e Contratos confidenciais.

Como proteger? Senhas fortes, Controle de acesso, Criptografia, ...

Se um funcionário acessa salários de colegas sem autorização, qual princípio foi violado?





Integridade

A informação deve permanecer correta, completa e sem alterações não autorizadas.

Garantir que as informações permaneçam íntegras durante todo o seu ciclo de vida.

Exemplos: Nota fiscal alterada, Saldo bancário modificado, Quantidade em estoque alterada, ...

Como proteger? Controle de versões, Assinatura digital, Controle de permissões ...

Se alguém altera o valor de uma transferência bancária de R\$ 100 para R\$ 1.000, qual princípio foi comprometido?



Disponibilidade

A informação deve estar acessível sempre que for necessária.

Garantir que usuários autorizados consigam acessar informações e sistemas no momento em que precisarem.

Exemplos: Hospital acessando prontuários, Banco realizando PIX, Indústria controlando produção ...

Como proteger? Backups, Monitoramento, Alta disponibilidade ...

Se o sistema do hospital fica fora do ar durante uma cirurgia, qual princípio foi comprometido?

Os três princípios trabalham juntos

Exemplo de Sistema Bancário: Imagine que um cliente acessou sua conta pelo aplicativo do banco.

Confidencialidade: Apenas o titular da conta consegue visualizar o saldo e o extrato.

Integridade: O saldo exibido corresponde exatamente ao valor real da conta, sem alterações indevidas.

Disponibilidade: O aplicativo e os servidores estão funcionando normalmente, permitindo o acesso sempre que necessário.

Conclusão: Uma informação só está realmente protegida quando é confidencial, íntegra e está disponível ao mesmo tempo.

Exemplo: Um hospital sofreu um ataque

Situação: Durante um ataque cibernético, um hospital enfrentou os seguintes problemas:

- Os prontuários dos pacientes foram vazados.
- Algumas informações médicas foram alteradas sem autorização.
- O sistema do hospital ficou fora do ar durante uma cirurgia.

Pergunta: Quais princípios da Tríade CIA foram comprometidos em cada situação? Justifique sua resposta.

- Os prontuários foram vazados. **Confidencialidade**
- As informações foram alteradas. **Integridade**
- O sistema ficou fora do ar. **Disponibilidade**

Por que proteger informações é tão importante?

Para as pessoas: Evita exposição de dados pessoais, Reduz fraudes e roubos de identidade e Preserva a privacidade.

Para as organizações: Evita prejuízos financeiros, Protege a reputação da empresa e Mantém a confiança de clientes e parceiros.

Aspecto legal: A Lei Geral de Proteção de Dados (LGPD) estabelece regras para o tratamento de dados pessoais. O descumprimento pode resultar em: Multas, Sanções administrativas e Perda de credibilidade.

Pergunta: Se uma empresa vazar dados de milhares de clientes, qual pode ser o maior prejuízo: financeiro ou de reputação?

R: Ambos! Porém, o prejuízo de **reputação** é ainda mais difícil de recuperar do que o **financeiro**. Uma multa pode ser paga, mas reconquistar a confiança dos clientes pode levar anos.

Prática

Em cada situação, qual princípio da Segurança da Informação foi comprometido?

Situação 1: Um funcionário acessou os salários de toda a empresa sem autorização.

Situação 2: O valor de uma transferência foi alterado de R\$ 500 para R\$ 5.000.

Situação 3: O sistema do hospital ficou fora do ar durante uma cirurgia.

Situação 4: Um aluno alterou sua própria nota no sistema da universidade.

Situação 5: Um colaborador enviou por engano uma planilha com dados pessoais de clientes para um fornecedor externo.

Prática

Em cada situação, qual princípio da Segurança da Informação foi comprometido?

Situação 1: Confidencialidade - Houve acesso a uma informação por alguém que não tinha autorização.

Situação 2: Integridade – A informação foi modificada indevidamente, comprometendo sua exatidão.

Situação 3: Disponibilidade - A informação e o sistema não estavam acessíveis quando eram necessários.

Situação 4: Integridade - A informação foi alterada sem autorização, comprometendo sua confiabilidade.

Situação 5: Confidencialidade – As informações confidenciais foram divulgadas a pessoas que não deveriam ter acesso.

De quem precisamos proteger essas informações?

- **Funcionário desatento:** Erros humanos podem expor informações ou facilitar incidentes de segurança.
- **Malware:** *Software* malicioso criado para roubar, danificar ou bloquear informações e sistemas.
- **Ataque cibernético:** Pessoa que tenta explorar vulnerabilidades para obter acesso não autorizado.
- **Incêndio:** Pode destruir equipamentos, documentos e interromper as operações da organização.
- **Queda de energia:** Interrompe sistemas e pode causar perda ou indisponibilidade de informações.
- **Falha de hardware:** Defeitos em computadores, servidores ou discos podem provocar perda de dados e indisponibilidade.

Qual dessas ameaças vocês acreditam ser a mais perigosa para uma empresa?

Nem toda ameaça é um *hacker*

Ameaças Humanas

- Ataques externos
- Funcionários
- Engenharia Social
- Senhas fracas

Ameaças Naturais e Técnicas

- Incêndios
- Falta de energia
- HD queimado
- Falhas de Internet

Muitas empresas sofrem mais com erros internos do que com *hackers*.

Pergunta: Quem vocês acham que representa o maior risco?

Resposta: Muitas pessoas pensam que os *hackers* representam o maior perigo. Porém, na maioria das organizações, o maior risco costuma ser o fator humano.

Ameaça × Vulnerabilidade × Risco

Ameaça: Algo que pode causar dano.



Vulnerabilidade: Uma fraqueza explorável.

Risco: A consequência caso a ameaça explore uma vulnerabilidade.

Sem vulnerabilidade, normalmente a ameaça não consegue agir.

Exemplo prático

Uma empresa possui:

- Notebook
- Senha: 123456
- Wi-Fi aberto
- Funcionários usam pen drives pessoais

Pergunta: Quais vulnerabilidades você consegue identificar?

Resposta: Senha fraca, Rede aberta e Uso de dispositivos externos.

Quanto mais vulnerabilidades, maior o risco.

Como os ataques realmente acontecem?

FLUXO 1: AMEAÇA → VULNERABILIDADE → RISCO



AMEAÇA

Algo que pode causar dano.



VULNERABILIDADE

Uma fraqueza explorável.



RISCO

A consequência caso a ameaça explore uma vulnerabilidade.



Sem vulnerabilidade, normalmente a ameaça não consegue agir.

FLUXO 2: EXEMPLO PRÁTICO



HACKER

Ameaça externa com intenção de causar dano.



SENHA FRACA

Vulnerabilidade que facilita o acesso não autorizado.



INVASÃO

A ameaça explora a vulnerabilidade e obtém acesso ao sistema.



ROUBO DE DADOS

Informações confidenciais são acessadas e extraídas.



PREJUÍZO

A empresa sofre perdas financeiras, danos à imagem e impactos legais.



Lembre-se: ataques acontecem em etapas. Prevenir em qualquer uma delas pode evitar o prejuízo.

ATIVIDADE





COMUNICADO

Backup realizado
Todo dia às 22h
Responsável: TI

VISITANTES
PREENCHER
IDENTIFICAÇÃO
↓

SALA
DE REUNIÃO

NOSSA POLÍTICA

- Segurança
- Confidencialidade
- Integridade
- Disponibilidade

AVISO

ÁREA
MONITORADA
24 HORAS

ARQUIVOS
2019 - 2022

FOLHA SALARIAL

CHAVE
SALA TI

PENRIVE
Backups

RELATÓRIO FINANCEIRO
2º SEMESTRE
2023

CONFIDENCIAL

Cliente
VIP
Obs: ligar

DADOS DE CLIENTES			E-mail
Nome	CPF	Telefone	
Ana Paula	123.456.789-00	(11) 91234-5678	ana@email.com
Carlos Silva	987.654.321-00	(11) 98765-4321	carlos@email.com
Jolo Santos	111.222.333-44	(11) 91111-2222	jolo@email.com
Mariana Lima	555.666.777-88	(11) 93333-4444	mariana@email.com
Roberto Alves	999.888.777-66	(11) 94444-5555	roberto@email.com

Proteção × Prevenção

Depois da auditoria realizada, como podemos reduzir os riscos identificados?

- Duas estratégias complementares:

Prevenção	Proteção
Busca reduzir a probabilidade de um incidente acontecer	Busca reduzir o impacto quando um incidente acontece
Atua antes do problema acontecer.	Atua durante ou após uma tentativa de ataque

Exemplos de Prevenção

- **Treinamento dos colaboradores:** reduz erros humanos e aumenta a conscientização sobre boas práticas.
- **Políticas de Segurança da Informação:** definem regras claras para acesso, uso e proteção das informações.
- **Conscientização sobre *phishing*:** prepara os usuários para reconhecer e evitar tentativas de fraude.
- **Atualizações de *software*:** corrigem falhas conhecidas que poderiam ser exploradas por atacantes.
- **Gestão de senhas:** incentiva o uso de senhas fortes e autenticação adequada.
- **Controle de visitantes:** evita o acesso de pessoas não autorizadas às áreas da organização.

O objetivo da prevenção é reduzir a probabilidade de que um problema ocorra.

Exemplos de Proteção

- **Firewall:** controla o tráfego de rede, permitindo ou bloqueando conexões conforme regras definidas.
- **Antivírus:** identifica, bloqueia e remove *softwares* maliciosos dos dispositivos.
- **Criptografia:** protege a confidencialidade das informações, tornando os dados ilegíveis para terceiros.
- **Controle de acesso:** garante que apenas usuários autorizados possam acessar informações e sistemas.
- **Backup:** permite recuperar dados em caso de perda, falha ou ataque.
- **Autenticação em dois fatores:** adiciona uma segunda camada de verificação, dificultando acessos indevidos mesmo quando a senha é comprometida.

O objetivo é reduzir os riscos e aumentar a capacidade da organização de prevenir, detectar e responder aos incidentes.

Discussão

Uma organização segura combina medidas de **prevenção** (evitar que o problema aconteça) com **mecanismos de proteção** (reduzir os impactos caso ele aconteça).

Analogia com a atividade:

- **Documento confidencial sobre a mesa:** prevenção (política de mesa limpa e treinamento).
- **Visitante circulando sem identificação:** prevenção (controle de visitantes).
- **Dados pessoais expostos:** prevenção (procedimentos e conscientização).
- **Perda dos documentos por incêndio ou falha:** proteção (*backup*, redundância e planos de recuperação).

Resumo

- **O valor da informação:** A informação é um dos ativos mais importantes de uma organização.
- **Segurança da Informação:** Proteger informações contra acessos, alterações, perdas e indisponibilidade.
- **Tríade CIA:** Confidencialidade, Integridade e Disponibilidade são os pilares da proteção da informação.
- **Ameaças:** Eventos ou agentes capazes de causar danos às informações.
- **Vulnerabilidades:** Fragilidades que podem ser exploradas por uma ameaça.
- **Riscos:** Consequências da exploração de uma vulnerabilidade por uma ameaça.
- **Prevenção:** Medidas para reduzir a probabilidade de incidentes.
- **Proteção:** Medidas para minimizar os impactos quando um incidente ocorre

OBRIGADO!

Até a próxima aula!

